



FUTURE INTERNS · CYBER SECURITY

Analysis of 3 Real Phishing Email Samples

Phishing Email Detection and Awareness Report

Prepared by Assia EL MOURTADAH

Future Interns — Cyber Security Internship (Task 2)



Table of Contents

Table of Contents	2
1. Executive Summary	3
2. Scope & Methodology	3
Tools Used.....	3
Analysis Approach	4
4. Email Analysis	5
Email 1 Fake “Microsoft Account Unusual Sign-in Activity” (Phishing)	5
Email 2 Fake “Costco” Free-Prize Scam (Phishing)	6
Email 3 Fake “Outlook Support Team” (Phishing)	6
5. Risk Classification Summary.....	7
6. How Phishing Works (Simple Explanation).....	7
7. Prevention & Awareness Guidelines	8
8. Conclusion.....	8

1. Executive Summary

The purpose of this assessment is to analyse real phishing email samples, identify the warning signs that reveal them, classify their risk, and produce a clear awareness document that employees can use to avoid falling victim to these attacks. The work was performed the way a security analyst would, using public phishing samples and free email-investigation tools.

Three real phishing email samples were collected from a public research dataset and analysed individually. All three were confirmed as phishing. Although they impersonate different brands and use different tricks, they share the same goal: to deceive the recipient into trusting the message and taking a harmful action.

Email Sample	Impersonated Brand	Classification
sample-1002	Microsoft account team	Phishing
sample-1714	Costco (prize / reward scam)	Phishing
sample-1878	Outlook / Microsoft Support	Phishing

The analysis shows that phishing is rarely stopped by technology alone one of the samples even passed all the standard email-authentication checks. The most effective defence is an aware user who recognises the warning signs. This report therefore ends with practical prevention guidelines and a clear list of Do's and Don'ts.

Note: all analysis was performed ethically and safely the emails were only read as plain text inside an isolated environment, no links were ever clicked, and no attachments were opened.

2. Scope & Methodology

This engagement was limited to the safe, read-only analysis of public phishing email samples. The objective was educational: to learn phishing detection and reporting, not hacking.

Tools Used

Tool	Purpose
Text inspection (cat / sed / grep)	Read the raw email and extract headers, key fields and links

Tool	Purpose
Google Admin Toolbox ;Messageheader	Analyse the authentication results (SPF / DKIM / DMARC)
VirusTotal	Check whether a domain / URL is known as malicious
urlscan.io	Safely inspect a link / domain in an isolated sandbox
base64 decoder	Reveal content hidden in encoded (base64) email bodies

Analysis Approach

- ✓ Read each email as plain text (never opened in a mail client that renders it).
- ✓ Extract the headers and the key fields: From, Reply-To, Return-Path, sending IP, Subject.
- ✓ Check the authentication results (SPF / DKIM / DMARC) in the header analyser.
- ✓ Inspect the sender domain and the links; defang URLs and scan them in VirusTotal / urlscan without visiting them.
- ✓ Identify the phishing indicators, then classify the risk as Safe / Suspicious / Phishing.

Safety rules followed throughout: work performed inside an isolated Kali virtual machine, links never clicked, attachments never opened, and suspicious URLs only submitted to scanners (which open them in their own sandbox, not in the analyst's browser).

3. Common Phishing Indicators

Across the three samples, the same warning signs appeared again and again. Learning to spot these is the single most effective protection against phishing.

Indicator	What it means (in simple terms)
Spoofed / fake sender domain	The real sender address does not match the brand it claims to be.
Mismatched addresses	From, Reply-To and Return-Path point to several different, unrelated domains.
Failed authentication	SPF / DKIM / DMARC checks fail, showing the sender is not authorised to use that domain.

Indicator	What it means (in simple terms)
Urgency & fear	Threats like “account locked” or “suspended in 24 hours” to rush you into acting.
Generic greeting	“Dear User / Dear Customer” instead of your real name.
Suspicious links	Odd domains, link shorteners, or links that hide their true destination.
Too-good-to-be-true offer	Prizes or rewards (e.g. a free product) used as bait.
Hidden / obfuscated content	Bodies encoded (base64) or abusing trusted services to slip past filters.

4. Email Analysis

Email 1 Fake “Microsoft Account Unusual Sign-in Activity” (Phishing)

Field	Value & observation
Display name	Microsoft account team (imitates Microsoft)
From (real)	no-reply@access-accsecurity[.]com , not a microsoft.com address
Reply-To	solutionteamrecognizd02@gmail[.]com ,a personal Gmail
Return-Path	bounce@thculturafdes[.]co[.]uk , a third, unrelated domain
Sending IP	89.144.44.2
SPF / DKIM / DMARC	none / none / permerror ,all fail
Suspicious link	hxxp://thebandalisty[.]com/track/... (hidden tracking pixel)

How this attack works: the email pretends Microsoft detected a suspicious login from Russia to frighten the recipient. The “Report the User” button actually opens a reply to the attacker's Gmail, so any panicked response goes straight to the criminal. The hidden tracking pixel tells the attacker the message was opened.

VirusTotal result: 11 of 92 security vendors flagged the link as Malicious / Phishing (Fortinet, Sophos, BitDefender, CRDF and others), confirming the verdict.

Classification: Phishing.

Email 2 Fake “Costco” Free-Prize Scam (Phishing)

Field	Value & observation
Display name	Costco (imitates the retailer)
From (real)	2gbf0@t63i2z7tgh[.]com , a random, meaningless domain
Return-Path	7ifgd36@mewahc[.]net , another unrelated domain
Sending IP	188.93.118.43
SPF / DKIM / DMARC	none / none / none + compauth=fail , all fail
Suspicious links	hxxps://t[.]co/... (shortener hiding destination) · hxxp://dtherhproblem[.]us/...

How this attack works: the email claims the recipient has won a free Keurig coffee maker. The excitement of a prize is the bait that pushes the victim to click. The real destination is hidden behind a link shortener, leading to an attacker-controlled site designed to collect personal information.

Red flags: a prize that is too good to be true, a brand name attached to a meaningless domain, link shorteners that conceal the true destination, and completely failed authentication.

Classification: Phishing.

Email 3 Fake “Outlook Support Team” (Phishing)

Field	Value & observation
Display name	Outlook Support Team (imitates Microsoft)
From (real)	social201711118@social.helwan.edu.eg , an Egyptian university, not Microsoft
Sending IP	40.107.14.44 (Microsoft 365 outbound , a compromised account)
SPF / DKIM / DMARC	pass / pass / bestguesspass , authentication PASSES
Sending tool	PHPMailer (a script, not a real support desk)
Body	encoded in base64 to hide its content from filters
Hidden link	hxxps://share.polymail[.]io/... a fake “Log in to your Microsoft account” page

How this attack works: the message comes from a real but hijacked university mailbox, so it passes the authentication checks. It pretends to be Outlook support,

claims the account is flagged, and threatens to suspend services within 24 hours pressuring the victim to click and “re-verify” on a fake Microsoft login page that steals their password.

Key lesson: SPF / DKIM / DMARC all passed, yet this is still phishing, because it was sent from a compromised legitimate account. Passing authentication does not mean an email is safe. The attacker also abused a trusted service (Polymail) to host the link and evade blocklists.

Classification: Phishing.

5. Risk Classification Summary

Email	Pretends to be	Main trick	Risk
sample-1002	Microsoft	Fake security alert + reply to attacker's Gmail	Phishing
sample-1714	Costco	Free-prize bait + hidden shortener link	Phishing
sample-1878	Outlook Support	Compromised account + 24h suspension threat	Phishing

Classification scale used: Safe (legitimate, authenticated, no warning signs); Suspicious (one or two warning signs, needs verification); Phishing (several clear indicators of deception). All three samples fall firmly in the Phishing category.

6. How Phishing Works (Simple Explanation)

Phishing almost always follows the same four steps, regardless of the brand being imitated:

Step	What the attacker does
1. Disguise	Pretends to be a trusted brand using a familiar name and logo.
2. Emotion	Creates fear (account locked) or excitement (you won a prize) so you react quickly.
3. The hook	Provides a link or button to a fake page, or a reply address that reaches the attacker.
4. The theft	Collects your password, personal details, or money once you act.

Understanding this pattern means that, even on a brand-new scam never seen before, an aware user can recognise the signs and stop at step 2 ,before any harm is done.

7. Prevention & Awareness Guidelines

The following practical guidelines help employees recognise and safely handle suspicious emails.

Do's

- Check the real sender address, not just the display name.
- Hover over links to preview the true destination before clicking.
- Be sceptical of urgency, threats, and offers that seem too good to be true.
- Go to the official website yourself by typing the address, instead of using email links.
- Enable multi-factor authentication (MFA) on your accounts.
- Report suspicious emails to your IT / security team.
- When in doubt, verify with the company through an official channel.

Don'ts

- Don't click links or buttons under pressure or panic.
- Don't open unexpected attachments.
- Don't enter your password or codes (OTP) on a page reached from an email.
- Don't reply with personal or financial information.
- Don't trust an email just because it “passed” security or looks professional.
- Don't forward a suspicious email to colleagues (report it instead).

Remember: authentication passing (SPF/DKIM/DMARC) does not guarantee an email is safe as Email 3 proved, a hijacked legitimate account can pass every check. The human check is the last and most important line of defence.

8. Conclusion

Three real phishing email samples were analysed in this assessment, and all three were confirmed as phishing. They impersonated different brands and used different tricks a fake security alert, a free-prize scam, and a hijacked support account but all relied on the same core technique: disguising themselves as trustworthy and using emotion to push the recipient into a harmful action.

A key finding is that technology alone cannot stop phishing. One sample failed every authentication check, yet another passed them all because it was sent from a

compromised legitimate account. This confirms that an aware, trained user is the most effective defence.

By learning the common indicators and following the Do's and Don'ts in this report, employees can confidently identify and report phishing attempts, protecting both themselves and their organisation.

Area	Takeaway
Detection	Check sender, authentication, links and tone for warning signs
Classification	Safe / Suspicious / Phishing based on the number of indicators
Protection	Verify independently, enable MFA, and report suspicious emails

All analysis was passive and ethical; no links were clicked and no attachments were opened.